ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

AutomationDirect Productivity Suite (Productivity Series PLC programming software) · Component type: **Software Application (SAR) - PLC programming / engineering software** · Target SL = SL 3

Where to work	**Productivity Suite** on a Windows host: the **project (.adpro)** with its optional **password / encryption**; the **Transfer** dialog (connect to the PLC by USB or Ethernet); firmware update; comms setup. There is **no multi-user account model** in the tool - access is governed by the **host Windows account** (who may run it) + the **project password**. The dominant control set is **PATCH to 4.7.0.47+**, protect the project, and harden the EWS. Installer from AutomationDirect (verify signature).
Ports / paths	Software-to-PLC over **USB** or **Ethernet** (to the PLC's Modbus TCP **502** / EtherNet/IP **44818** / programming); the tool historically **bound to an unrestricted IP address** (a CVE - patch + host-firewall it). Projects (.adpro) + backups live on the host. No TLS on the software-to-PLC link (MQTTS is a PLC-side option). Runs on Windows; harden + patch the host.
Notes / CVEs	SAR - AutomationDirect Productivity Suite. **PATCH-CRITICAL**: CISA **ICSA-25-296-01** - **CVE-2025-61977** weak password recovery (decrypt a project by answering one recovery question), **relative path traversal**, **incorrect permission assignment**, and **binding to an unrestricted IP address** -> RCE / info disclosure / full project takeover (two flaws can hijack the kernel). **Update to 4.7.0.47+** and patch the PLC firmware (ICSA-24-144-01). The EWS is an OT-perimeter target (Nozomi) - treat it as high-value.
How to read	Each row = native step-by-step (Productivity Suite / host) + command-level external-tool steps. Default read-only. Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization. Given the EWS CVEs, several rows hinge on PATCHING + host hardening.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the Productivity Suite project (.adpro) with its password / encryption settings, the tag + hardware configuration export, and the logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 1.1	Human user identification & auth	Confirm access is layered: (1) the host **Windows account** controls who may run Productivity Suite; (2) opening a protected **project** requires its **password**. Note the **weak password-recovery CVE (CVE-2025-61977)** let an attacker decrypt a project by answering one recovery question - **patch to 4.7.0.47+** so the password cannot be bypassed. **Test:** open a password-protected .adpro without the password -> denied; confirm the patched version (recovery-question bypass removed). **Ext. tools:** Productivity Suite (project password + Help › About version); host account review; confirm version >= 4.7.0.47.	Host restricts execution; project password enforced; patched so recovery cannot bypass it.	Patch-critical.
SR/CR 1.2	Software process / device identification	Confirm the tool connects only to intended PLCs (by IP/USB) and that the historical **unrestricted-IP-bind** behavior is patched + host-firewalled so it does not listen broadly. **Ext. tools:** Productivity Suite (target PLC list); `netstat -ano` on the host (confirm not bound to 0.0.0.0 on untrusted interfaces after patch); host firewall review.	Connects to intended PLCs only; no broad listening socket (patched + firewalled).	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 1.3	Account management	Manage the host/AD accounts allowed to run Productivity Suite (least privilege) and the custody of the **project password**; the **incorrect-permission-assignment CVE** affected file/resource permissions - patch and confirm tight host ACLs. **Ext. tools:** Host/AD account review; project-password custody; confirm patched + host ACLs on the install/project dirs.	Host identities least-privilege; project password controlled; permissions patched/tightened.	
SR/CR 1.4	Identifier management	Confirm unique host user IDs and unique project/PLC identities (project name, PLC IP/serial); no reuse. **Ext. tools:** Host/AD; Productivity Suite (project/PLC list).	Unique user and project/PLC identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Set a **strong project password**; **patch CVE-2025-61977** so the recovery mechanism cannot bypass it; enforce host/AD password policy for the EWS login; consider MFA at the host/AD layer. **Ext. tools:** Productivity Suite (password + patched version); host/AD policy (`gpresult /h gp.html`).	Strong project password (recovery patched); host/AD policy; MFA where feasible.	
SR 1.6	Wireless access management	**N/A.** Software with no wireless interface; wireless is a host/network concern. **Ext. tools:** Confirm no software wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A / limited.** The software-to-PLC link has no TLS/PKI (MQTTS is a PLC-side option). Record N/A; the project encryption protects the project at rest (patch the weak recovery); rely on host disk encryption + segmentation. **Ext. tools:** Confirm no software TLS to the PLC; confirm project encryption + patched Suite; BitLocker status.	N/A/limited software PKI; project encrypted (patched); host encryption compensates.	N/A/Partial.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the project-password and any host login mask entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	The project password had a **weak recovery** bypass (patch); there is no native lockout - compensate with host/AD lockout for the EWS login and monitoring. **Ext. tools:** Host/AD lockout policy; confirm patched Suite; SIEM (EWS auth events).	Recovery patched; host lockout; failures monitored.	
SR/CR 1.12	System use notification	No software banner; enforce the approved use notice on the Windows host (GPO logon banner). **Ext. tools:** Host `gpresult /h gp.html` (legalnoticetext).	Use notice at the host (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Run Productivity Suite on a **hardened EWS in the OT zone**, not exposed to untrusted networks; the **unrestricted-IP-bind CVE** means it could be reachable broadly - **patch** + host-firewall so it does not listen on untrusted interfaces; remote engineering via VPN/jump host. **Test:** from an untrusted VLAN, reach any Productivity Suite listening port on the EWS -> must fail. **Ext. tools:** `nmap -Pn` from the untrusted side (expect no Suite ports); `netstat -ano` on the host; firewall review.	EWS not reachable from untrusted networks; broad listening removed (patched + firewalled); remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.1	Authorization enforcement	Authorization is the **project password** (gates project access/transfer) + the host (only authorized users run the tool). The **incorrect-permission-assignment CVE** weakened resource permissions - patch and confirm least-privilege host ACLs on the install/project directories. **Test:** as a non-authorized host user, run Productivity Suite / open a protected project -> denied. **Ext. tools:** Host ACL review; Productivity Suite (project password); confirm patched.	Project access gated by password + host; resource permissions patched/least-privilege.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the EWS laptop and removable media (OS device-control); protect the **.adpro projects**; only authorized installers/firmware loaded; restrict who runs Productivity Suite. **Ext. tools:** Host removable-media GPO; project ACL; installer provenance.	Portable/engineering media + projects controlled.	
SR/SAR 2.4	Mobile code	No general-purpose mobile code; confirm only the signed Productivity Suite runs and no untrusted add-ons; the **relative-path-traversal CVE** was a file-handling flaw - patch, and only open **trusted project files** (malicious projects were an attack vector). **Ext. tools:** Installed-component signature review; confirm patched; project-file provenance.	Only signed software; path-traversal patched; only trusted projects opened.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; Productivity Suite re-opens require host + project auth. **Ext. tools:** Host inactivity-lock GPO.	Host locks on inactivity; re-auth required.	Compensating.
SR/CR 2.6	Remote session termination	The tool is not a multi-user server; confirm remote-access (VPN/jump) sessions to the EWS can be terminated and idle sessions close (host/VPN policy). **Ext. tools:** VPN/jump session review; host RDP idle-timeout.	EWS remote sessions terminable; idle sessions close.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm engineering actions are attributable: Productivity Suite **project change tracking** records config changes, and the host audit log records who ran the tool / transferred a project; forward EWS logs to the SIEM. The EWS is a key OT-perimeter monitoring point (Nozomi). **Ext. tools:** Productivity Suite (project change history); host audit (Security log) + SIEM.	Changes attributable (project history + host audit); forwarded to the SIEM.	
SR/CR 2.9	Audit storage capacity	Confirm the host audit + SIEM are sized/retained and alert on collection failure so EWS events are not silently lost. **Ext. tools:** Host log sizing; SIEM source-silent alert.	Logs sized/offloaded; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the EWS is NTP-synced so project-history + host-audit timestamps correlate with the SIEM. **Ext. tools:** `w32tm /query /status`; SIEM time review.	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.1	Communication integrity	The software-to-PLC link (USB/Ethernet) is **not TLS-protected** - keep it inside the segmented OT zone; the **unrestricted-IP-bind CVE** (patch) could expose a listening socket. No cleartext engineering traffic crosses a zone boundary. **Test:** confirm engineering traffic stays in-zone and the EWS exposes no broad listening socket (patched). **Ext. tools:** Wireshark (engineering traffic in-zone); `netstat -ano` + `nmap` (no broad Suite ports).	Engineering link contained in-zone; broad listening removed (patched); no uncontrolled cleartext.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only the **signed** Productivity Suite from AutomationDirect (verify the installer signature); host anti-malware / **application whitelisting** (CISA-recommended); restrict install/upgrade to admins; **patch to 4.7.0.47+** (the advisory fixes six CVEs, two of which can hijack the kernel). **Ext. tools:** `signtool verify /pa .exe`; host AV/whitelisting; Help › About (version >= 4.7.0.47).	Signed software validated; whitelisting active; install restricted; patched to 4.7.0.47+.	SAR-specific / patch-critical.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 3.3	Security functionality verification	After any change re-verify: patched version (4.7.0.47+), project protection, host ACLs/firewall (no broad bind), and host hardening, against the baseline. **Ext. tools:** Help › About (version); host ACL/firewall review; `netstat -ano`.	Security settings match the hardening baseline after change; patched.	
SR/CR 3.4	Software & information integrity	Protect the **.adpro projects**: host ACLs, encrypt at rest (BitLocker), version + change-track; use the project encryption (patch the weak-recovery CVE); hash projects; detect drift with project compare. **Ext. tools:** Host ACL on projects; `certutil -hashfile .adpro SHA256`; Productivity Suite compare; BitLocker status.	Projects protected + change-tracked; integrity baselined; encryption patched.	
SR/CR 3.5	Input validation	Patch the **relative-path-traversal** + the other file-handling CVEs (ICSA-25-296-01); the tool parses project files, so a malicious .adpro was an attack vector - only open trusted projects; scan the EWS for the known CVEs. **Ext. tools:** Nessus/OpenVAS on the EWS (Productivity Suite CVEs); CISA/AutomationDirect cross-check; confirm patched; project-file provenance.	Known CVEs patched; only trusted projects opened; no path-traversal path.	SAR-specific.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors are handled gracefully without leaking sensitive info (no plaintext project passwords/keys in logs/crash dumps). **Ext. tools:** Productivity Suite / host event-log review.	Graceful error handling; no secret leak.	
SR/CR 3.8	Session integrity	**Limited.** The software-to-PLC link is not an authenticated/encrypted session; integrity by containment. Any remote EWS access is over VPN/RDP (integrity-protected). Record the level. **Ext. tools:** Confirm VPN/RDP for remote EWS; Wireshark (engineering link in-zone).	Remote EWS access integrity-protected (VPN/RDP); engineering link contained.	Partial.
SR/CR 3.9	Protection of audit information	Protect the host audit log + SIEM store and the project change history; restrict who can read/clear them (host ACLs + SIEM roles). **Ext. tools:** Host audit ACL; SIEM access review.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose of the EWS, remove the projects, the project passwords/encryption keys, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** Remove projects/backups; confirm no plaintext secrets; BitLocker status.	Projects, secrets, and keys purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm the project encryption is used (and the weak-recovery CVE patched); the EWS disk is encrypted (BitLocker). Note the software-to-PLC link is not encrypted - compensate with segmentation. **Ext. tools:** Confirm project encryption + patched Suite; BitLocker; segmentation review.	Project encrypted (patched) + host disk encrypted; engineering link compensated by segmentation.	Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 5.1	Network segmentation	Run Productivity Suite on a **hardened EWS in a segmented OT zone**; the **unrestricted-IP-bind CVE** means it could listen broadly - **patch** + host-firewall; only required engineering flows to the PLC cross; remote via a jump host; no flat convergence with IT. **Ext. tools:** Host firewall + `netstat -ano`/`nmap` (no broad Suite ports); zone/firewall review.	EWS in a segmented zone; broad listening removed; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Engineering software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: dedicate the EWS to engineering (do not co-host unrelated apps/browsing), least-privilege host access, and separate project scopes per site/zone. **Ext. tools:** EWS role review (dedicated); host access review.	EWS dedicated/partitioned; least-privilege; project scopes separated.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 6.1	Audit log accessibility	Confirm the project change history + host audit are readable/exportable and forwarded to the SIEM; the **EWS is an OT-perimeter target** (Nozomi) - run EDR on it and monitor for exploitation of the known CVEs. **Ext. tools:** Productivity Suite (change export); host audit + SIEM; EWS EDR alerts.	Events accessible/exportable and monitored; EWS under EDR/SIEM.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 7.1	Denial-of-service protection	The tool is not a runtime service; confirm the EWS is resourced/hardened and the **unrestricted-IP-bind** listening socket is removed (patch) so it cannot be a network DoS/RCE vector; do not co-host unrelated apps. **Ext. tools:** Host resource monitor; confirm patched + no broad bind (`netstat -ano`).	EWS resourced/hardened; broad listening removed; not a network vector.	
SR/CR 7.2	Resource management	Confirm bounded host resource use; the EWS is dedicated so a single app cannot starve engineering access. **Ext. tools:** Host resource monitor; dedicated-EWS review.	Host resources bounded; engineering access available.	
SR/CR 7.3	Control system backup	Confirm the **.adpro projects** (with their passwords managed) are backed up (versioned, offline) and a restore/rebuild of the EWS + project is tested. **Ext. tools:** Backup repository; restore test (lab EWS).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: **patch to 4.7.0.47+**, run on a hardened least-privilege EWS, application whitelisting, host firewall (remove the broad bind), disable unused features, install only the signed tool, and only open trusted projects. **Ext. tools:** Help › About (version); host hardening + firewall review; `nmap` .	Least functionality; patched; whitelisting; broad bind removed.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / CVEs
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the Productivity Suite version + build and the OS so vulnerabilities track against AutomationDirect / CISA advisories (ICSA-25-296-01 Suite; ICSA-24-144-01 PLC). **Ext. tools:** Help › About / installed components; CISA / AutomationDirect advisory feed.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Productivity Suite	Native project/security review (all FRs)	Review the project password/encryption, project change history, target-PLC list, comms, and firmware; confirm the version (Help › About) is 4.7.0.47+; back up the .adpro.	Read/authorized project copy.
signtool / Digital Signatures	Signed-installer validation (SAR 3.2)	`signtool verify /pa .exe` or Properties › Digital Signatures; download only from AutomationDirect.	Read-only.
netstat / nmap	EWS listening-surface & the IP-bind CVE (1.2, 1.13, 3.1, 5.x, 7.1)	`netstat -ano` on the host + `nmap` from another zone; confirm no broad/unrestricted Productivity Suite listener after patching + host firewall.	Read-only; authorized.
Host firewall / GPO	EWS hardening (1.13, 5.x, 7.6, 1.12)	Restrict Suite listening to required interfaces; enforce logon banner, screen-lock, and removable-media policy; application whitelisting.	Authorized; change-controlled.
Nessus / OpenVAS + CISA / AutomationDirect advisories	CVE scan (3.5, 7.8)	Scan the EWS for the Productivity Suite CVEs; cross-check ICSA-25-296-01 (CVE-2025-61977 + path traversal + permissions + IP-bind); confirm 4.7.0.47+.	ISOLATED/representative; authorization.
EWS EDR + SIEM	Monitoring the OT-perimeter workstation (2.8, 6.x)	Run EDR on the EWS (Nozomi: it is an OT-perimeter target); forward host audit + project-change events to the SIEM; alert on CVE-exploitation.	Coordinate with SOC.
certutil / BitLocker	Project integrity & at-rest (3.4, 4.x)	`certutil -hashfile .adpro SHA256` for drift; confirm host disk encryption; project encryption enabled (patched).	Read-only.
Wireshark / tcpdump	Engineering-link containment (3.1, 3.8)	Confirm the software-to-PLC engineering traffic stays inside the segmented OT zone (no cleartext crossing a boundary).	Passive; SPAN/tap only.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.